

Narrativa explicativa del marco GQM + PRAGMATIC para indicadores GRC

1. De los objetivos país al log de firewall

La tentación habitual en ciberseguridad nacional es medir lo que está a mano: incidentes, vulnerabilidades, compras de tecnología, titulares. El resultado suele ser un mosaico de cifras que impresiona en las ruedas de prensa, pero guía poco en las decisiones estratégicas. El enfoque GQM + PRAGMATIC intenta invertir la lógica: primero se define qué queremos lograr como país, después qué preguntas debemos hacer, y solo entonces decidimos qué métricas merece la pena perseguir.[web:9][web:12][web:13]

GQM nos recuerda que cada métrica sin objetivo es una distracción; PRAGMATIC, que no toda métrica con objetivo es útil si no cumple unos mínimos de relevancia, accionabilidad, precisión y coste razonable.

2. La capa GQM: poner nombre a las prioridades

En el contexto español y europeo, los objetivos no faltan: implementar NIS2, reforzar la resiliencia de los servicios esenciales, alinear la inversión con el riesgo y cumplir las promesas de la Década Digital.[web:9][web:12][web:5] Lo difícil es traducir esas consignas en algo que pueda responder una organización concreta sin recurrir a metáforas.

La capa GQM hace precisamente eso: por ejemplo, el objetivo “reforzar la gobernanza de ciberseguridad” se despliega en preguntas como “¿Tiene la organización una estrategia aprobada?”, “¿Existe un CISO con acceso al consejo?” y “¿Se reportan métricas al máximo órgano de gobierno?”. A partir de ahí, las métricas dejan de ser abstracciones: se convierten en porcentajes claros de organizaciones que cumplen o no cumplen con lo que se ha definido como buena práctica.[web:9][web:3]

3. La capa PRAGMATIC: discriminar entre métricas útiles y souvenirs

Sin embargo, la experiencia en marcos como NIS360, NIST CSF o los índices industriales demuestra que es fácil caer en el coleccionismo de métricas.[web:9][web:12][web:1] Se mide todo lo medible sin preguntarse si esas mediciones ayudan a anticipar problemas, priorizar recursos o explicar algo inteligible a un ministro.

Aquí entra PRAGMATIC. Cada indicador nacional se somete a nueve preguntas incómodas: ¿predice algo o solo describe el pasado? ¿Está realmente conectado con un objetivo relevante? ¿Sugiere acciones concretas? ¿Se puede medir con precisión razonable? ¿Es oportuno, independiente, rentable? Las métricas que obtienen puntuaciones bajas deben ser reformuladas o abandonadas, por muy “interesantes” que parezcan.

4. Ejemplos de métricas “buenas” y métricas “decorativas”

Una métrica como “porcentaje de organizaciones críticas con BCP/DRP que incluyen ciberataques y se prueban periódicamente” tiene una fuerte carga PRAGMATIC: está directamente vinculada a resiliencia,

su ausencia implica riesgos claros, y su mejora se traduce en acciones concretas (desarrollar y probar planes).[web:3][web:9]

En cambio, una métrica como “número total de alertas de seguridad procesadas por año” suele puntuar peor: es difícil de comparar entre organizaciones, está sujeta a múltiples sesgos (configuración de herramientas, umbrales, falsos positivos) y raro es el político que puede extraer de ella una decisión sensata sin un tratado de estadística aplicada.

El mensaje no es prohibir estas métricas operativas, sino reservarlas para el nivel que les corresponde (SOC, equipos técnicos) y no elevarlas sin filtro al plano nacional y estratégico.

5. Trazabilidad y responsabilidad

La gracia del enfoque GQM es que deja un rastro claro: cada métrica está conectada a una pregunta, y cada pregunta a un objetivo. Cuando un indicador nacional “rojo” genera preocupación, se puede trazar hacia abajo qué prácticas organizativas lo están alimentando y, en sentido inverso, qué reformas normativas o de política pública podrían modificarlo.

Este hilo de trazabilidad es especialmente valioso en un entorno regulatorio complejo como el europeo: ayuda a mostrar cómo las exigencias de NIS2, DORA, ENS o ISO 27001 se traducen en cambios concretos de gobernanza, gestión de riesgos, cumplimiento y capacidades en las organizaciones españolas.[web:9][web:12][web:5][web:13]

6. Una métrica no hace primavera

La narrativa nacional no puede construirse a partir de un único número milagroso. Ni el IGM ni ningún índice compuesto sustituye el análisis detallado. Pero sí proporciona un idioma común para el diálogo entre responsables políticos, reguladores, CISOs y sociedad: permite decir “estamos en tal nivel en gobernanza, peor en resiliencia, razonables en Zero Trust, y estos son los sectores en zona de riesgo”. [web:9][web:12][web:1]

La clave es usar los indicadores como brújula, no como arma arrojada. Una puntuación baja en una métrica PRAGMATIC bien diseñada no es un fracaso, sino un diagnóstico. Lo preocupante sería tener métricas perfectas en el papel e incidentes cada vez más graves en la práctica.

7. Cerrar el círculo: de la medición a la decisión

El marco GQM + PRAGMATIC solo tiene sentido si termina en decisiones: reasignar recursos, ajustar regulaciones, priorizar sectores, diseñar programas de apoyo y formación, reforzar capacidades nacionales. Del mismo modo que un CISO no vive para rellenar cuadros de mando, un país no debería medir su ciberseguridad para engordar memorias anuales.

En el mejor de los casos, este marco permitirá que, dentro de algunos años, podamos contestar con cierta evidencia a preguntas tan sencillas y tan complicadas como: “¿Somos hoy más resilientes que en 2025? ¿En qué lo notan nuestros hospitales, nuestra red eléctrica, nuestras pymes?”. Si las respuestas se parecen más a datos que a deseos, el esfuerzo habrá merecido la pena.